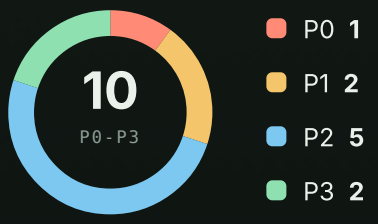
Audyt: sklep.example (dane przykładowe)

3 źródeł dowodów: Known-vulnerability lookup (OSV.dev, CISA KEV) · Expert review (model judgment) · Website posture check - https://shop.example/

Działaj dziś

Co najmniej jeden problem jest krytyczny lub aktywnie wykorzystywany.

10	0
OTWARTE USTALENIA	POTWIERDZONE POPRAWKI
842	**2**
SPRAWDZONE PAKIETY	POMYSŁY NA ULEPSZENIA



ZACZNIJ TUTAJ

Trzy najważniejsze rzeczy

P0

Table public.orders is readable by anyone: row-level security is off

ALTER TABLE public.orders ENABLE ROW LEVEL SECURITY; add a policy USING (auth.uid() = customer_id). Rollback: DISABLE ROW LEVEL SECURITY.

P1

Order lookup trusts the ID in the URL (missing ownership check)

Filter the query by the session's customer id and return 404 when it does not match.

P1

lodash 4.17.20: CVE-2021-23337

Update to 4.17.21 or later through the official channel.

GDZIE JEST RYZYKO



USTALENIA

P0 Baza danych expert review - model judgment `expert-review`

Table public.orders is readable by anyone: row-level security is off

CO MOŻE SIĘ STAĆ

Anyone who opens the shop can download every customer's orders and addresses with the public key shipped in the page.

CO ZAOBSERWOWANO

pg_tables.rowsecurity = false for public.orders; role anon holds SELECT.

JAK TO NAPRAWIĆ

ALTER TABLE public.orders ENABLE ROW LEVEL SECURITY; add a policy USING (auth.uid() = customer_id). Rollback: DISABLE ROW LEVEL SECURITY.

JAK SPRAWDZIĆ POPRAWKĘ

Re-run the pg_tables query, then request the table with the public key: it must return only the caller's rows.

P1 Kod expert review - model judgment `expert-review`

Order lookup trusts the ID in the URL (missing ownership check)

CO MOŻE SIĘ STAĆ

A logged-in customer can read another customer's order by changing the number in the address bar.

CO ZAOBSERWOWANO

src/routes/orders.ts:42 loads the order by req.params.id without comparing it to the session user.

JAK TO NAPRAWIĆ

Filter the query by the session's customer id and return 404 when it does not match.

JAK SPRAWDZIĆ POPRAWKĘ

Request another account's order id: expect 404. Add a regression test.

P1 Zależności tool evidence `dependencies`

lodash 4.17.20: CVE-2021-23337

CO MOŻE SIĘ STAĆ

Command injection through the template function.

CO ZAOBSERWOWANO

Installed version is inside a published affected range. Severity high (CVSS 7.2). Known exploited: no.

JAK TO NAPRAWIĆ

Update to 4.17.21 or later through the official channel.

JAK SPRAWDZIĆ POPRAWKĘ

Collect a fresh inventory and re-run advisories.

P2 Zależności tool evidence dependencies

example-http-client 1.2.0: SYNTHETIC-2026-0001

CO MOŻE SIĘ STAĆ

Synthetic example: a redirect can leak an authorization header to another host.

CO ZAOBSERWOWANO

Installed version is inside a published affected range. Severity medium (CVSS 5.3). Known exploited: no.

JAK TO NAPRAWIĆ

Update to 1.2.4 or later through the official channel.

JAK SPRAWDZIĆ POPRAWKĘ

Collect a fresh inventory and re-run advisories.

P2 Zależności tool evidence dependencies

example-yaml-parser 3.0.1: SYNTHETIC-2026-0002

CO MOŻE SIĘ STAĆ

Synthetic example: deeply nested input can exhaust memory.

CO ZAOBSERWOWANO

Installed version is inside a published affected range. Severity medium (CVSS 5.9). Known exploited: no.

JAK TO NAPRAWIĆ

Update to 3.0.5 or later through the official channel.

JAK SPRAWDZIĆ POPRAWKĘ

Collect a fresh inventory and re-run advisories.

P2 Strona WWW tool evidence website

Cookie "session" is missing HttpOnly, SameSite.

CO ZAOBSERWOWANO

WEB-COOKIE-001: Cookie value not recorded.

JAK TO NAPRAWIĆ

Set Secure, HttpOnly and SameSite=Lax on session cookies.

JAK SPRAWDZIĆ POPRAWKĘ

Re-run the website check and compare finding IDs.

P2 Strona WWW tool evidence website

No Content-Security-Policy: no browser-side limit on injected scripts.

CO ZAOBSERWOWANO

WEB-CSP-001: Content-Security-Policy is absent.

JAK TO NAPRAWIĆ

Start with default-src 'self'; object-src 'none'; base-uri 'self'; frame-ancestors 'self' in report-only mode, then enforce it.

JAK SPRAWDZIĆ POPRAWKĘ

Re-run the website check and compare finding IDs.

P2 Strona WWW tool evidence website

No HSTS header: browsers may be downgraded to HTTP.

CO ZAOBSERWOWANO

WEB-HSTS-001: Strict-Transport-Security is absent.

JAK TO NAPRAWIĆ

Send Strict-Transport-Security: max-age=31536000; includeSubDomains once every subdomain supports HTTPS.

JAK SPRAWDZIĆ POPRAWKĘ

Re-run the website check and compare finding IDs.

WARTO DOPRACOWAĆ

P3 Strona WWW tool evidence website

The server header reveals software and version.

CO ZAOBSERWOWANO

WEB-DISCLOSURE-001: server: nginx/1.18.0

JAK TO NAPRAWIĆ

Remove or genericise the header. Then confirm the disclosed product is on a supported, patched version.

JAK SPRAWDZIĆ POPRAWKĘ

Re-run the website check and compare finding IDs.

P3 Strona WWW tool evidence website

No security.txt: researchers have no clear way to report a problem.

CO ZAOBSERWOWANO

WEB-SECTXT-001: /.well-known/security.txt answered 404

JAK TO NAPRAWIĆ

Publish /.well-known/security.txt with a contact and expiry (RFC 9116).

JAK SPRAWDZIĆ POPRAWKĘ

Re-run the website check and compare finding IDs.

IDEA Zależności expert review - model judgment expert-review

Check dependencies automatically on every pull request

CO ZAOBSERWOWANO

No dependency scan in the CI workflow.

JAK TO NAPRAWIĆ

Add a lockfile scan (for example osv-scanner) to CI and fail the build on new high-severity advisories.

IDEA | Strona WWW | expert review - model judgment | expert-review

Add rate limiting to login and password reset

CO ZAOBSERWOWANO

No rate limit observed in the gateway configuration.

JAK TO NAPRAWIĆ

Limit attempts per account and per address, and alert on bursts.

POKRYCIE I OGRANICZENIA

REPORT	EVIDENCE	DATE
dependencies	Known-vulnerability lookup (OSV.dev, CISA KEV)	2026-11-10 09:12
expert-review	Expert review (model judgment)	2026-11-10 09:40
website	Website posture check - https://shop.example/	2026-11-10 09:20

- A match means the installed version string falls in a published affected range. It does not prove the vulnerable code is reachable or exploitable here.
- No match is not proof of safety: databases lag and distributions backport fixes.
- Passive check of one URL's response headers, cookies flags and TLS handshake. It cannot see logic flaws, injection, broken access control or anything behind a login.

Defensywna kontrola tylko do odczytu. Ustalenia są sygnałami do zbadania, a nie certyfikatem bezpieczeństwa. Brak ustalenia nie dowodzi bezpieczeństwa. Każdą zmianę wdrażasz samodzielnie.